



信息安全技术 基础知识



课程内容提要



- 信息安全基础 (★★)
- 信息加解密技术 (★★★)
- 密钥管理技术 (★★)
- 访问控制及数字签名技术 (★★★)
- 信息安全的保障体系



信息安全基础



◆ 信息安全包括5个基本要素：

名称	说明
机密性	机密性是指网络信息不泄露给非授权的用户、实体或程序，能够防止非授权者获取信息。
完整性	完整性是指网络信息或系统未经授权不能进行更改的特性。
可用性	可用性是指合法许可的用户能够及时获取网络信息或服务的特性。
可控性	可控性是指可以控制授权范围内的信息流向及行为方式。
可审查性	可审查性是指对出现的信息安全问题提供调查的依据和手段。

信息安全的范围包括**设备安全、数据安全、内容安全**和**行为安全**。



信息安全基础



◆ 网络安全漏洞

安全隐患主要表现为：

- 1、物理安全性。
- 2、软件安全漏洞。
- 3、不兼容使用安全漏洞。
- 4、选择合适的哲理。



信息安全基础



◆ 网络安全威胁

网络安全威胁主要表现形式如下：

- 1、非授权访问。
- 2、信息泄露或丢失。
- 3、破坏数据完整性。
- 4、拒绝服务攻击。
- 5、利用网络传播病毒。



信息安全基础



◆ 安全措施的目标

安全措施的目标如下：

- 1、访问控制。
- 2、认证。
- 3、完整性。
- 4、审计。
- 5、保密。



习题讲解



在进行软件系统安全性分析时，（ ）保证信息不泄露给未授权的用户、实体或过程；完整性保证信息的完整和准确，防止信息被非法修改；（ ）保证对信息的传播及内容具有控制的能力，防止为非法者所用。

A. 完整性 B. 不可否认性 C. 可控性 D. 机密性

A. 完整性 B. 安全审计 C. 加密性 D. 可控性

安全性是根据系统可能受到的安全威胁的类型来分类的。其中，（ ）保证信息不泄露给未授权的用户、实体或过程；（ ）保证信息的完整和准确，防止信息被篡改。

A. 可控性 B. 机密性 C. 安全审计 D. 健壮性

A. 可控性 B. 完整性 C. 不可否认性 D. 安全审计



信息加解密技术



【对称加密】



【特点】

- 1、加密强度不高，但效率高，易破解。
- 2、密钥分发困难。

【非对称加密】



【特点】

- 1、加密强度高，但效率低，极难破解。
- 2、密钥分发容易。

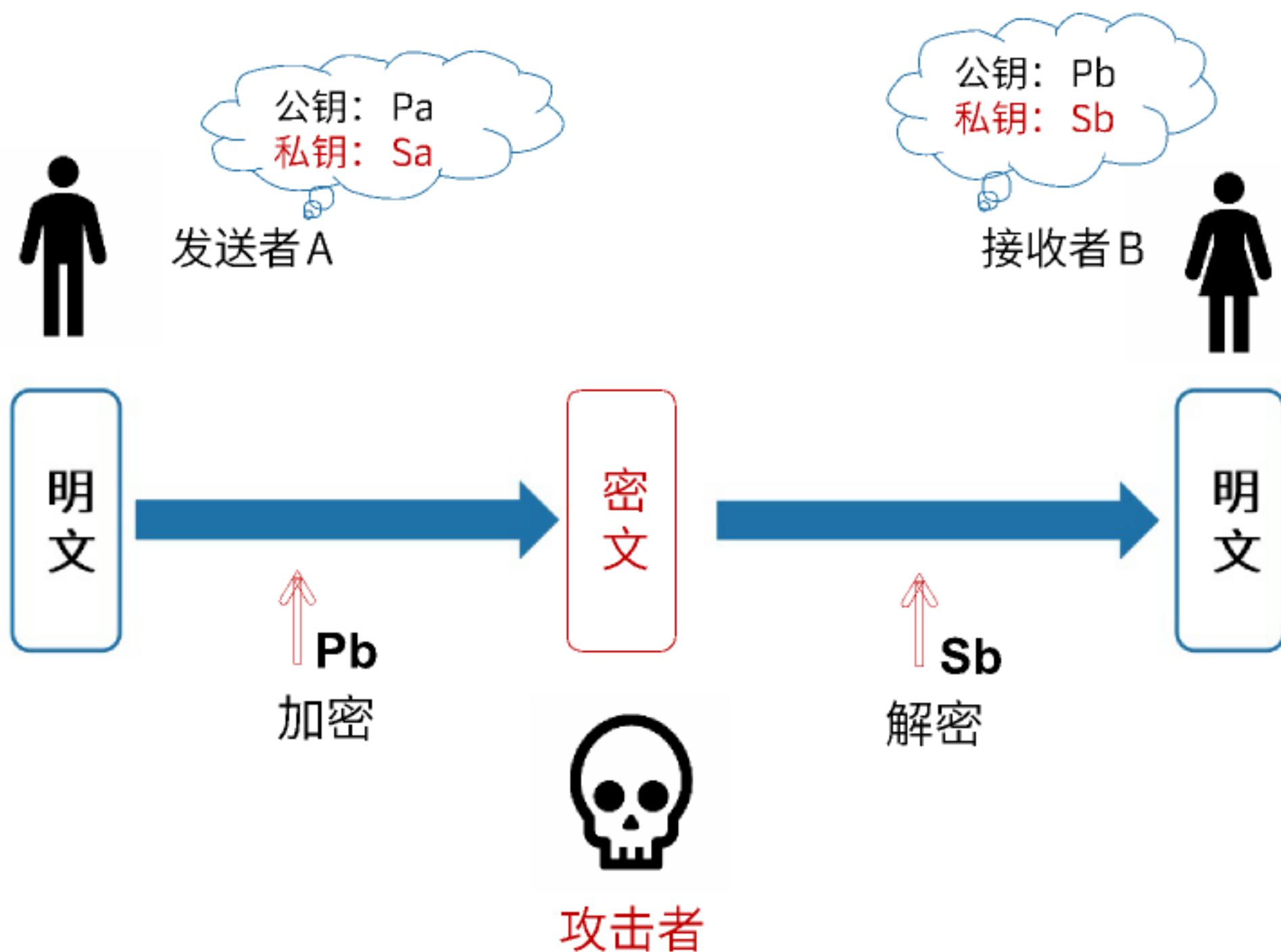


信息加解密技术



【游戏规则】

任何人的【私钥】，只有自己拥有
任何人的【公钥】，可以明文公开发送





信息加解密技术



对称加密算法【共享密钥】	非对称加密算法【公开密钥】
【用途】对消息明文进行加密传送	【用途】对密钥加密，做数字签名
❑ DES：替换+移位、56位密钥、64位数据块、速度快、密钥易产生 ❑ 3DES（三重DES） 密钥长度112【两个56位的密钥K1、K2】 加密：K1加密->K2解密->K1加密 解密：K1解密->K2加密->K1解密 ❑ IDEA：128位密钥、64位明文/密文、PGP ❑ 其它对称加密算法：RC-5、AES	■ RSA：2048位（或1024位）密钥 ■ Elgamal：安全性依赖于计算有限域上离散对数这一难题 ■ ECC：椭圆曲线算法 ■ Diffie-Hellman



习题讲解



一个密码系统至少由明文、密文、加密算法、解密算法和密钥五个部分组成，而其安全性是由（ ）决定的。

- A. 加密算法
- B. 解密算法
- C. 加解密算法
- D. 密钥

利用公开密钥算法进行数据加密时，采用的方式是（ ）。

- A. 发送方用公开密钥加密，接收方用公开密钥解密
- B. 发送方用私有密钥加密，接收方用私有密钥解密
- C. 发送方用公开密钥加密，接收方用私有密钥解密
- D. 发送方用私有密钥加密，接收方用公开密钥解密



习题讲解



公司总部与分部之间需要传输大量数据，在保障数据安全的同时又要兼顾密钥算法效率，最合适的加密算法是（ ）。

- A. RC-5
- B. RSA
- C. ECC
- D. MD5



密钥管理技术

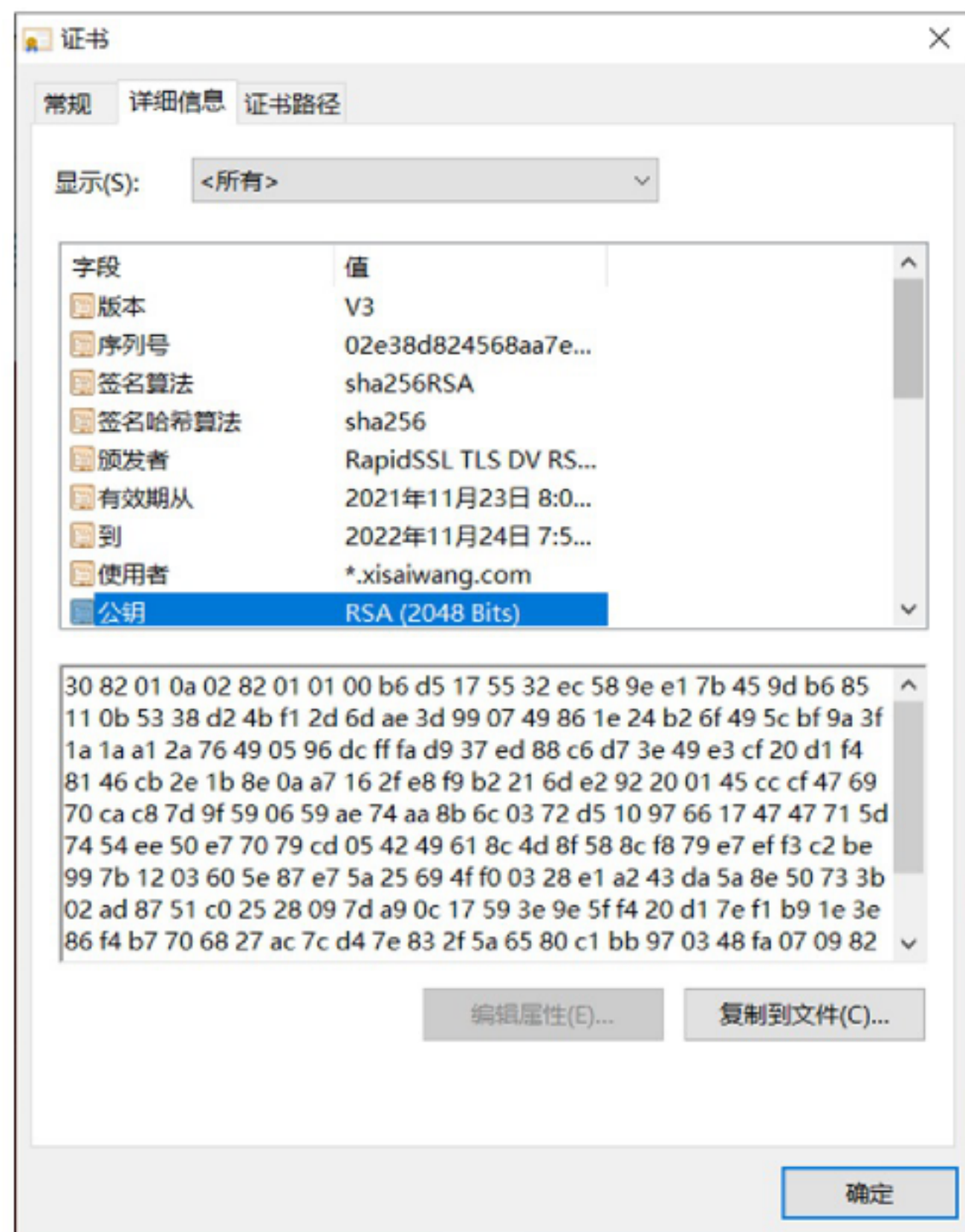


◆ 数字证书内容

- 证书的**版本信息**；
- 证书的**序列号**，每个证书都有一个唯一的证书序列号；
- 证书所使用的签名算法；
- 证书的发行机构名称，命名规则一般采用X.500格式；
- 证书的**有效期**，现在通用的证书一般采用UTC时间格式，它的计时范围为1950-2049；
- 证书所有人的名称，命名规则一般采用X.500格式；
- 证书所有人的**公开密钥**；
- **证书发行者对证书的签名。**



密钥管理技术





密钥管理技术



◆ PKI公钥体系

❖ CA (Certificate Authority)

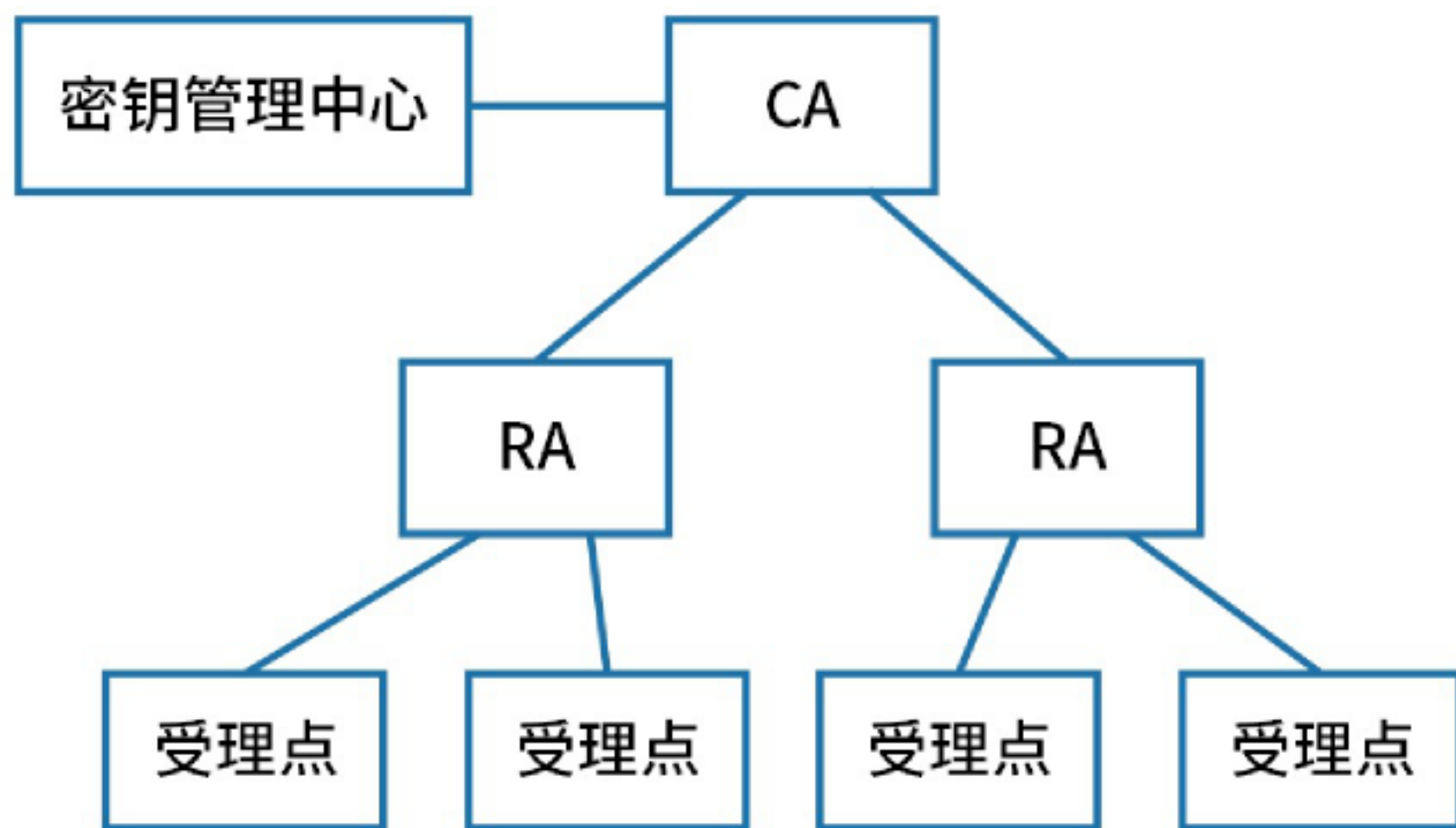
认证中心

❖ RA (Registration Authority)

注册审批机构

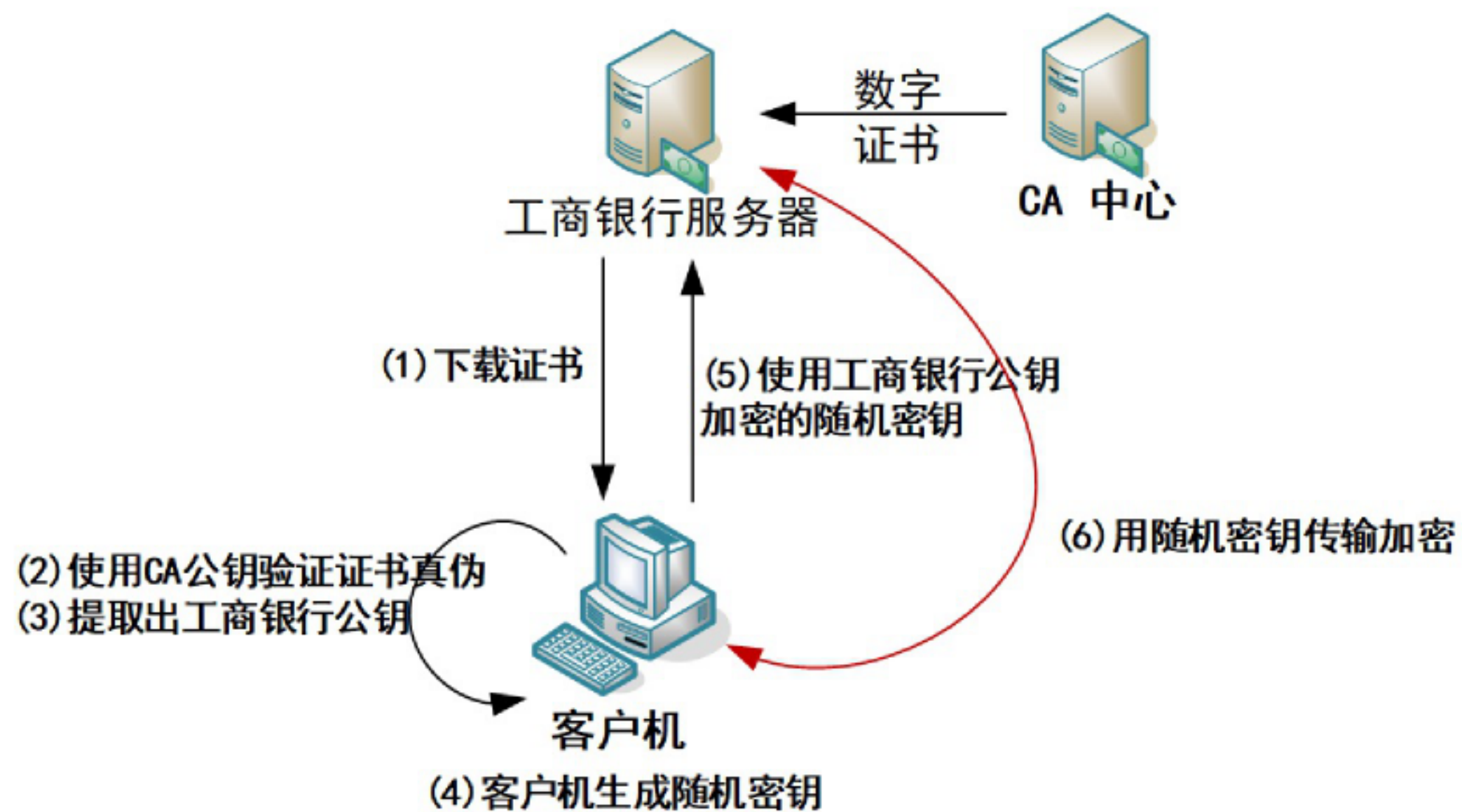
❖ 证书受理点

❖ 密钥管理中心-KMC





密钥管理技术





习题讲解



公钥基础设施（Public Key Infrastructure, PKI）引入数字证书的概念，用来表示用户的身份。下图简要地描述了终端实体（用户）从认证权威机构CA申请、撤销和更新数字证书的流程。请为中间框空白处选择合适的选项（ ）。



- A. 证书库
- B. RA
- C. OCSP
- D. CRL库



习题讲解



在PKI体系中，注册机构RA的功能不包括（ ）。

- A. 签发证书
- B. 认证注册信息的合法性
- C. 批准证书的申请
- D. 拒绝证书的申请

某Web网站向CA申请了数字证书。用户登录过程中可通过验证（ ），确认该数字证书的有效性，以（ ）。

- A. CA的签名
 - B. 网站的签名
 - C. 会话密钥
 - D. DES密码
-
- A. 向网站确认自己的身份
 - B. 获取访问网站的权限
 - C. 和网站进行双向认证
 - D. 验证该网站的真伪



访问控制技术



◆ 访问控制的基本模型

访问控制的目标有两个：

- 防止非法用户进入系统；
- 阻止合法用户对系统资源的非法使用，即禁止合法用户的越权访问。

访问控制的三要素：

- **主体：**可以对其他实体施加动作的主动实体，记为S；
- **客体：**是接受其他实体访问的被动实体，记为O；
- **控制策略：**是主体对客体的操作行为集和约束条件集，记为KS。



访问控制技术



◆ 访问控制的实现技术

访问控制矩阵（ACM）：矩阵中的每一格表示所在行的主体对所在列的客体的访问授权。

	file1	file2	file3
User1	rw		rw
User2	r	rwX	x
User3	x	r	



访问控制技术

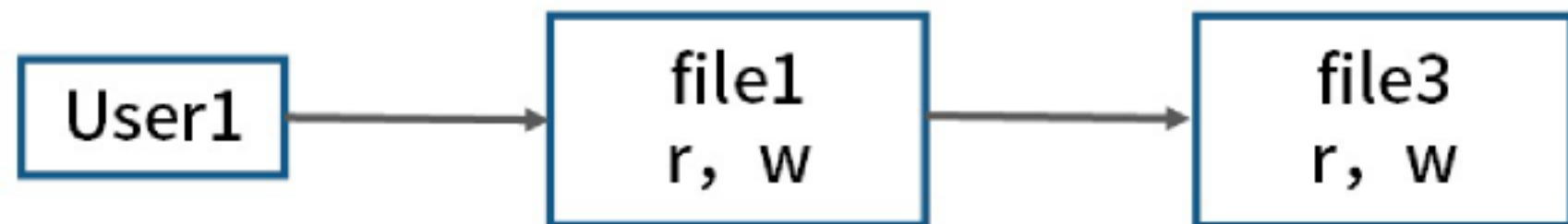


◆ 访问控制的实现技术

访问控制列表：访问控制矩阵按列分解，具体如下：



能力表：访问控制矩阵按行分解，具体如下：



授权关系表：对应访问矩阵中每一个非空元素的实现技术。像安全数据库系统通常用授权关系表来实现其访问控制安全机制。

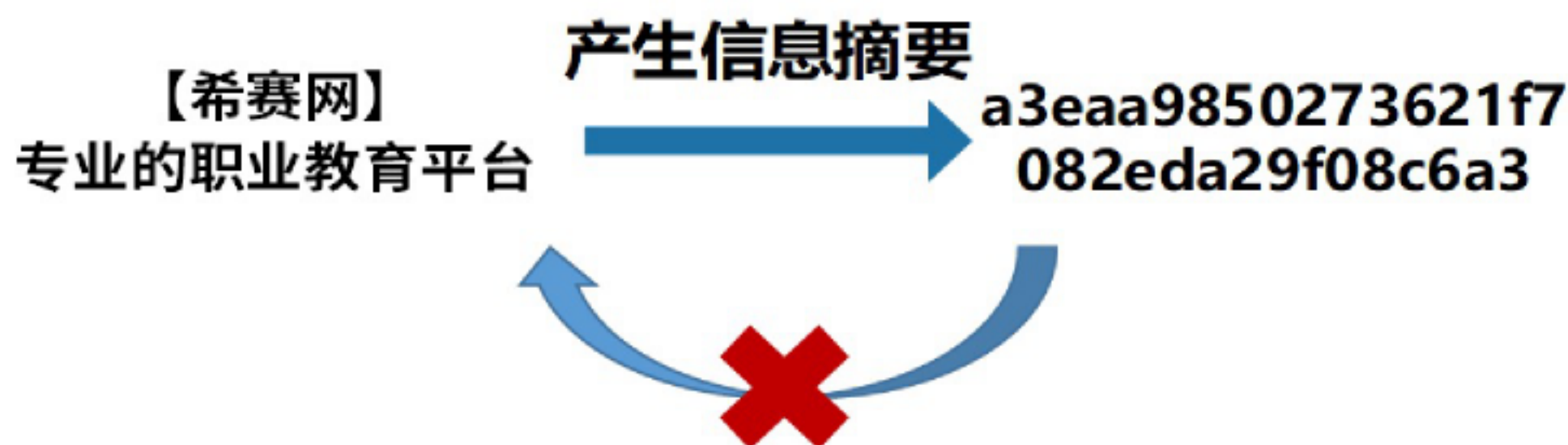


数字签名技术



信息摘要：单向散列函数【不可逆】、固定长度的散列值。

摘要用途：确保信息【完整性】，防篡改。



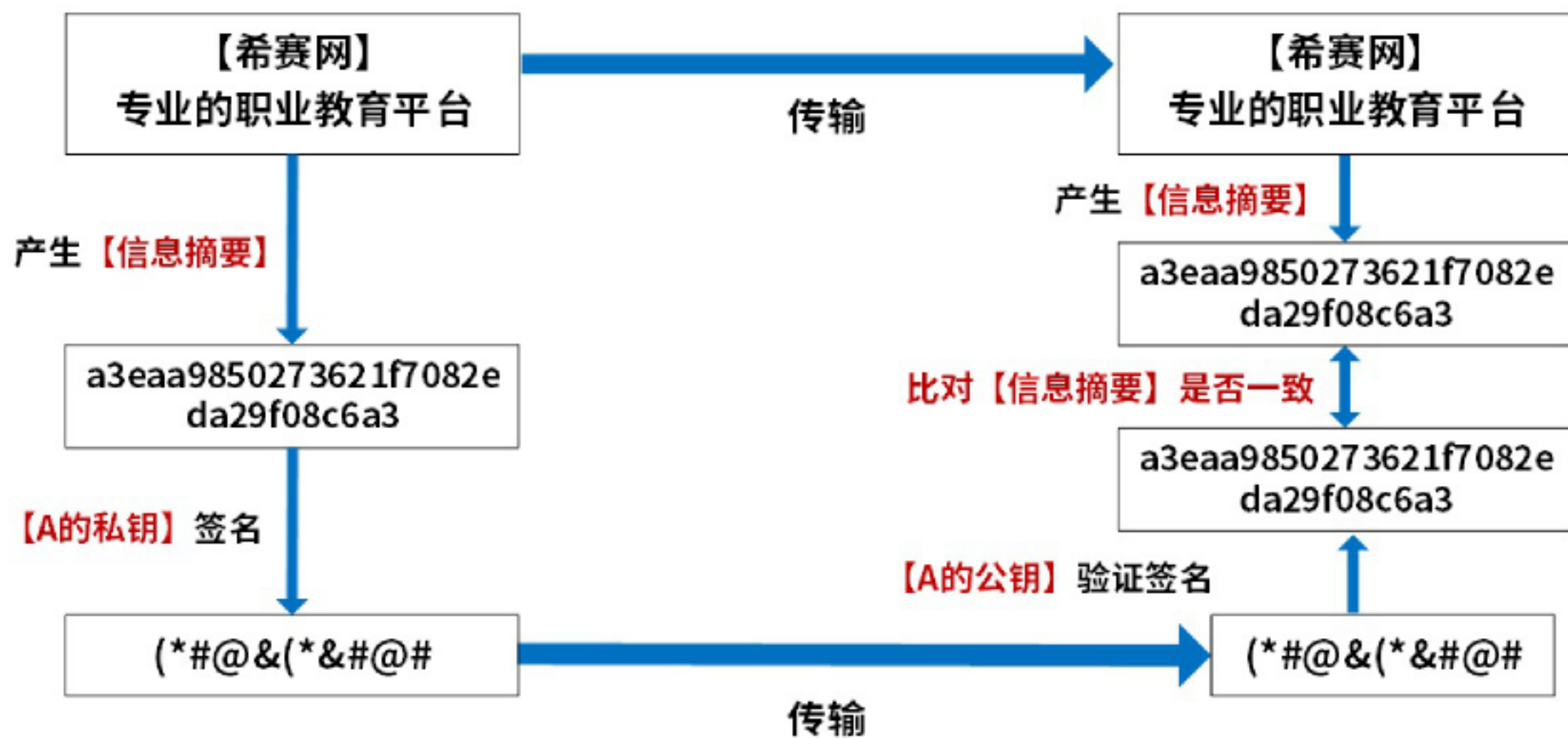
常用的消息摘要算法有MD5、SHA等，市场上广泛使用的MD5、SHA算法的散列值分别为128和160位，由于SHA通常采用的密钥长度较长，因此安全性高于MD5。



数字签名技术



数字签名过程分析





国产密码算法



◆ 国产密码算法

算法名称	算法特性描述	备注
SM1	对称加密，分组长度和密钥长度都为128比特	广泛应用于电子政务、电子商务及国民经济的各个应用领域
SM2	非对称加密，用于公钥加密算法、密钥交换协议、数字签名算法	国家标准推荐使用素数域256位椭圆曲线
SM3	杂凑算法，杂凑值长度为256比特	适用于商用密码应用中的数字签名和验证
SM4	对称加密，分组长度和密钥长度都为128比特	适用于无线局域网产品
SM9	标识密码算法	不需要申请数字证书，适用于互联网应用的各种新兴应用的安全保障



练习题



请依据已学习的加密解密技术，以及信息摘要、数字签名技术解决以下问题：

请设计一个安全邮件传输系统，要求：

该邮件以加密方式传输，邮件最大附件内容可达2GB，发送者不可抵赖，若邮件被第三方截获，第三方无法篡改。



练习题



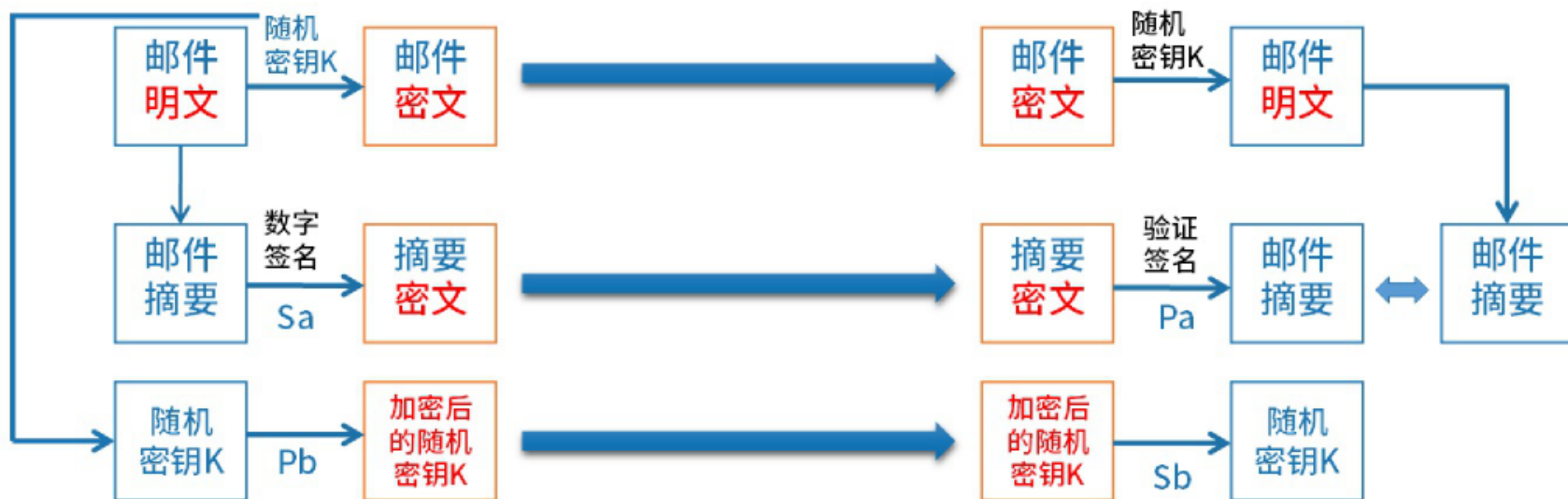
该邮件以加密方式传输，邮件最大附件内容可达2GB，发送者不可抵赖，若邮件被第三方截获，第三方无法篡改。

加密解密技术 对称加密 数字签名

信息摘要技术

发送方A（公钥：Pa，私钥：Sa）：

接收方B（公钥：Pb，私钥：Sb）：





习题讲解



以下属于访问控制的目标的是（ ）。

- A. 防止非法用户进入系统
- B. 防止病毒进入系统
- C. 防止内网用户访问外网
- D. 防止外网用户访问内网

数字签名最常见的实现方法是建立在（ ）的组合基础之上。

- A. 公钥密码体制和对称密码体制
- B. 对称密码体制和MD5摘要算法
- C. 公钥密码体制和单向安全散列函数算法
- D. 公证系统和MD4摘要算法



习题讲解



数字签名首先需要生成消息摘要，然后发送方用自己的私钥对报文摘要进行加密，接收方用发送方的公钥验证真伪。生成消息摘要的目的是（ ），对摘要进行加密的目的是（ ）。

- | | | | |
|---------|---------|---------|---------|
| A. 防止窃听 | B. 防止抵赖 | C. 防止篡改 | D. 防止重放 |
| A. 防止窃听 | B. 防止抵赖 | C. 防止篡改 | D. 防止重放 |



信息安全的保障体系



◆ 计算机信息系统安全保护等级

计算机信息系统安全保护等级划分准则 (GB 17859-1999)

✓ 用户自主保护级：适用于普通内联网用户

系统被破坏后，**对公民、法人和其他组织权益有损害**，但不损害国家安全社会秩序和公共利益。

✓ 系统审计保护级：适用于通过内联网或国际网进行商务活动，需要保密的非重要单位

系统被破坏后，**对公民、法人和其他组织权益有严重损害**，或**损害社会秩序和公共利益**，但不损害国家安全。

✓ 安全标记保护级：适用于地方各级国家机关、金融机构、邮电通信、能源与水源供给部门、交通运输、大型工商与信息技术企业、重点工程建设等单位

系统被破坏后，对**社会秩序和公共利益造成严重损害**，或对**国家安全造成损害**。

✓ 结构化保护级：适用于中央级国家机关、广播电视部门、重要物资储备单位、社会应急服务部门、尖端科技企业集团、国家重点科研机构 and 国防建设等部门

系统被破坏后，对**社会秩序和公共利益造成特别严重损害**，或对**国家安全造成严重损害**。

✓ 访问验证保护级：适用于国防关键部门和依法需要对计算机信息系统实施特殊隔离的单位

系统被破坏后，对**国家安全造成特别严重损害**。



信息安全的保障体系



◆ 计算机信息系统安全保护等级

	公民、法人和其他组织权益	社会秩序和公共利益	国家安全
用户自主保护级	损害		
系统审计保护级	严重损害	损害	
安全标记保护级		严重损害	损害
结构化保护级			严重损害
访问验证保护级			特别严重损害



习题讲解



依据国家信息安全等级保护相关标准，军用不对外公开的信息系统的安全等级至少应该属于（ ）。

- A. 二级及二级以上
- B. 三级及三级以上
- C. 四级及四级以上
- D. 五级